UBP UNIVERSIDAD BLAS PASCAL

Título:

Plan Estratégico de Madurez en Ciberseguridad: Un Modelo de Resiliencia para el Sector Salud

Organización:

Clínicas Privadas del Centro S.A. (Ficticia)

Datos del Estudiante: Lucas Nahuel Caminos

Diplomatura en Ciberseguridad

Tema Elegido y Justificación

La ciberseguridad en el sector salud ha transitado de ser un problema técnico a un imperativo de negocio y de seguridad del paciente. El presente trabajo propone un plan estratégico de ciberseguridad para "Clínicas Privadas del Centro S.A.", una red de sanatorios de mediana escala ficticia, radicada en la provincia de Córdoba.

Se ha seleccionado esta organización en lugar de un caso de estudio genérico (como "Contoso") por una razón metodológica fundamental: permite demostrar la construcción de un programa de ciberseguridad desde un nivel de madurez inicial (reactivo), en lugar de simplemente optimizar un sistema maduro. Este escenario "Greenfield" (en términos de estrategia de seguridad) es académicamente más rico, ya que permite aplicar el ciclo de vida completo de un programa de ciberseguridad, desde la justificación y evaluación (Unidad I y II), pasando por la prevención focalizada (Unidad III), hasta la planificación de la respuesta (Unidad IV).

La organización opera en un entorno de riesgo máximo. La convergencia de tecnología *legacy* (infraestructura y software obsoletos), datos altamente sensibles (regulados por la Ley 25.326) y una dependencia operativa absoluta (un sistema de gestión de pacientes caído frena por completo la facturación y la atención médica) crea la "tormenta perfecta" para un incidente disruptivo como el ransomware.

El objetivo de este plan no es proponer una seguridad "infalible" (concepto que la Unidad IV define como inexistente), sino establecer un modelo de resiliencia progresivo y económicamente viable para una PyME. Se priorizarán las acciones que permitan justificar la inversión (Unidad II), prevenir los vectores de ataque más probables (Unidad III) y garantizar la continuidad del negocio (Unidad IV) mediante una evaluación estructurada (Unidad I).

Desarrollo del Tema

1. Descripción de la Organización (Versión Revisada y Detallada)

Nombre: Clínicas Privadas del Centro S.A.

Rubro y Contexto: Salud. Red de 3 clínicas privadas (Córdoba Capital, Río Cuarto, Villa María).

Dimensionamiento: 450 empleados totales, incluyendo personal médico (médicos, enfermeros), personal administrativo (recepción, facturación, RRHH) y personal de maestranza.

Sector IT (Estado Actual): El departamento de "Sistemas" está compuesto por 3 personas: 1 Jefe de Sistemas (rol generalista) y 2 técnicos de Soporte (Help Desk).

- **Justificación de Estado:** No existe un rol de CISO, ni personal dedicado exclusivamente a la seguridad. El equipo está sobrecargado con la operación diaria (soporte a usuarios, gestión de impresoras, mantenimiento de sistemas) y carece de tiempo y especialización para una gestión proactiva de la ciberseguridad.

Infraestructura y Herramientas (Detalle Técnico):

- **Infraestructura On-Premise (Data Center):** La sede central de Córdoba Capital alberga un (1) rack principal con 5 servidores físicos (hosts de virtualización).
    - **Sistemas Operativos:** 3 hosts corren Windows Server 2012 R2 (fuera de soporte estándar) y 2 corren Windows Server 2019.
    - **Virtualización:** Se ejecutan aproximadamente 15 máquinas virtuales (VMs) sobre Hyper-V.
    - **Almacenamiento:** Un (1) SAN (Storage Area Network) centraliza el almacenamiento de las VMs.

- **Sistemas Críticos (Software y VMs):**
  - **HIS/EMR:** El sistema de gestión de pacientes (HIS/EMR) es un software "legacy" de un proveedor nacional. Críticamente, corre sobre una VM con Windows Server 2012 R2 y se conecta a una base de datos SQL Server 2008 R2 (ambos obsoletos y altamente vulnerables).
  - **Controlador de Dominio:** Dos (2) VMs actúan como Controladores de Dominio (Active Directory), con un nivel funcional de 2012 R2.
  - **Servidor de Archivos:** Una (1) VM (Windows Server 2016) actúa como *File Server* central, alojando estudios (radiografías, PDFs) y documentos administrativos sensibles (RRHH, Finanzas).
- **Infraestructura Cloud:**
  - **Correo y Ofimática:** Se utiliza Microsoft 365, plan Business Standard. Este plan incluye las aplicaciones básicas pero carece de las herramientas de seguridad avanzadas (como *Defender for Office 365 P1/P2* o *Azure AD Premium* para políticas de acceso condicional).
  - **Portal Web:** El portal de turnos web para pacientes está alojado en una VM IaaS (Linux/Apache) en un proveedor de nube local.
- **Redes y Conectividad:**
  - **Segmentación:** La red es peligrosamente plana. Existe una VLAN "Interna" (ej. 192.168.1.0/24) para *todo*: PCs administrativas de RRHH y Finanzas, estaciones de trabajo de médicos en consultorios, impresoras y los servidores del Data Center. Una segunda VLAN "Invitados" provee Wi-Fi a pacientes, pero la separación con la red interna es la única segmentación existente.
  - **Acceso Remoto:** El acceso para proveedores (soporte del HIS) y personal administrativo se realiza mediante VPN y RDP (Remote Desktop Protocol) publicado directamente en el firewall, sin Autenticación Multifactor (MFA).
- **Seguridad y Continuidad (Estado Actual):**
  - **Perímetro:** Un (1) firewall NGFW (ej. Fortinet) con licencias de suscripción básicas (solo *firewalling* y VPN, sin ATP, *sandboxing* ni filtrado web avanzado).
  - **Endpoints:** Antivirus tradicional (ej. ESET) gestionado por una consola local.
  - **Monitoreo:** No existe un SIEM, un SOC, ni gestión de logs centralizada. Las alertas son las que reporta el antivirus o los usuarios.
  - **Backups:** La política de backup es el punto más débil. Los backups de las VMs se realizan a un NAS (Network Attached Storage) ubicado en la misma red del Data Center. Este NAS es replicado, de forma manual e inconsistente, a un disco USB externo que el Jefe de Sistemas rota "cuando se acuerda". El NAS es visible y accesible desde la red interna, convirtiéndolo en un objetivo primario para el ransomware.

Nivel de Madurez (Según Unidad I)**: Reactivo / Inicial.**

- **Justificación:** La ciberseguridad se atiende ante fallos (evaluación esporádica). No se gestionan vulnerabilidades conocidas (ej. Win 2012 R2), los riesgos de acceso (RDP) son altos y la estrategia de backup no resistiría un ataque de ransomware moderno.

2.1. Esquema de Evaluación de Escenarios

Justificación Lógica (Unidad I): Dada la madurez "Reactiva" de la organización, es logísticamente incorrecto proponer un ejercicio avanzado de *Red Team*. El informe resultante sería abrumador y el equipo de IT de 3 personas no podría gestionar los hallazgos. El objetivo inicial no es la auditoría exhaustiva, sino establecer un diagnóstico de riesgo que sirva como herramienta para justificar la inversión ante la Dirección. Por ello, se propone un esquema de evaluación progresivo en tres fases.

Fase 1 (Inmediata): Evaluación de Cumplimiento (Gap Analysis vs. Ley 25.326)

Esta es la primera acción y la palanca de cambio principal. Como se vio en la Unidad I, la Evaluación de Cumplimiento es un pilar fundamental. Dado que la clínica maneja "datos personales sensibles" (historias clínicas), está directamente obligada por la Ley 25.326. Esta evaluación medirá la brecha de la organización contra el Artículo 9 (Medidas de Seguridad) y el

Artículo 20 (Evaluaciones periódicas). El resultado no será una opinión técnica, sino un informe de riesgo legal y financiero que obliga al Directorio a actuar.

- **Responsable de Implementación:** Un Proveedor Externo (Estudio Legal-Técnico). El equipo de IT interno no posee la formación jurídica para interpretar la ley y su jurisprudencia. Se debe contratar una consultora local especializada que traduzca los requisitos legales en controles técnicos accionables.

Fase 2 (Corto Plazo): Análisis de Vulnerabilidades (Automatizado)

Tras establecer la obligatoriedad legal, el siguiente paso es la "higiene" técnica básica. Como se define en la Unidad I, la Evaluación de Vulnerabilidades es el primer nivel de testeo técnico ("evaluación esporádica"). Su objetivo es identificar las vulnerabilidades conocidas ("low-hanging fruit") en los activos críticos. Este análisis arrojará resultados de criticidad ALTA inmediatos, como los servidores Windows Server 2012 R2 y SQL Server 2008 R2 (detallados en la Sección 1), además de la configuración del portal web. Este informe será la hoja de ruta para el proceso de *Patch Management* (Unidad III).

- **Responsable de Implementación:** El **IT Interno (Jefe de Sistemas)**. Esta es una tarea realista para el equipo actual. El Jefe de Sistemas puede ejecutar una herramienta (como OpenVAS, o la versión de prueba de Nessus) para generar el informe inicial y comenzar a priorizar los parches críticos.

Fase 3 (Mediano Plazo): Ethical Hacking (Demostración de Impacto)

El objetivo de esta fase **no es encontrar** vulnerabilidades (la Fase 2 ya las habrá identificado), sino **demostrar la *explotabilidad* y el *impacto negocio***. El Análisis de Vulnerabilidades (Fase 2) le dice a la Dirección: "Usted tiene una cerradura débil". Este Ethical Hacking (Fase 3) les demuestra: "Usando esa cerradura débil, logré entrar, moverme por todos sus pasillos sin ser detectado y ahora tengo la llave de su bóveda de historias clínicas".

El escenario (Grey Box) será acotado: "Demostrar la cadena de ataque completa, desde una PC de 'Recepción' (usuario con privilegios mínimos) hasta lograr exfiltrar un registro de la base de datos del HIS/EMR".

- **Justificación Lógica (Unidad I y III):** Esta prueba es la única forma de justificar la inversión en controles caros como la **Microsegmentación de Red** (Unidad III) y un **SOC/SIEM** (Unidad I). El resultado no es un listado de parches, sino la prueba de que un **movimiento lateral** es posible y que la organización está "ciega" (no tiene detección).
- **Responsable de Implementación:** Un **Proveedor Externo (Consultora "boutique" local)**. Es crucial que el proveedor entienda la realidad PyME (Unidad I - "Consideraciones para contratación"). La clínica debe buscar un socio en el ecosistema local (ej. Cybersecurity Hub de Córdoba) cuyo entregable clave no sea un listado técnico, sino un resumen ejecutivo de riesgo de negocio para presentar al Directorio.

2.2. Cultura Corporativa y Plan de Concientización

Punto de Partida (Cultura): La cultura de ciberseguridad es **inexistente**. Existe una "cultura de velocidad" donde el personal médico y administrativo prioriza la atención rápida del paciente sobre la seguridad. Esto se traduce en prácticas de alto riesgo: credenciales de HIS compartidas, sesiones dejadas abiertas en consultorios y uso indiscriminado de dispositivos USB personales. La seguridad es percibida como "un problema de Sistemas" que entorpece la operación.

Objetivo Estratégico (Unidad II): Implementar el cambio de paradigma definido en la Unidad II: abandonar la idea del "usuario como eslabón más débil" (un problema sin solución) y adoptar el concepto del "Firewall Humano". El objetivo no es que *nadie* caiga en un phishing, sino que *al menos un* empleado consciente lo detecte y lo reporte a tiempo, convirtiéndose en un sensor de detección.

Justificación Lógica (Unidad IV): El análisis forense (Gráfico Unidad IV) demuestra que el Phishing (44%) es el vector de entrada #1. Por lo tanto, un programa de *awareness* continuo es el control preventivo con el mayor Retorno de Inversión (ROI) contra la amenaza más probable.

Plan de Concientización Continuo:

Audiencia 1: Dirección General (El "Por Qué" de la Inversión)

La acción clave es el Table-Top Exercise (Unidad II). Esta es la herramienta de concientización diseñada para directivos. Se debe realizar una sesión de 2 horas (no más, para respetar su agenda) facilitada por un consultor externo. El escenario simulará un ataque de Ransomware con Doble Extorsión (Unidad III): "Son las 9 AM del lunes. El sistema HIS está cifrado. Los atacantes claman tener 50.000 historias clínicas y amenazan con publicarlas en 48 horas. ¿Qué hacemos?". Esta simulación obliga al Director General, Director Médico, Jefe de Legales y Jefe de Finanzas a confrontar el impacto operativo real (el *downtime* promedio de 3 semanas citado en la Unidad IV), las decisiones de pago (Unidad IV) y las consecuencias legales de la filtración (Ley 25.326).

- **Responsable:** Un **Consultor Externo** (como facilitador) y el **Comité de Crisis** (como participantes).

Audiencia 2: Personal (El "Cómo" de la Defensa)

El plan para los 450 empleados debe ser **continuo**, no un evento anual (Unidad II). El equipo de IT de 3 personas no puede crear y gestionar este contenido.

- **Acción 1: Implementación de Plataforma de Awareness Gestionada.** Se debe contratar una plataforma de *Security Awareness* (como SMARTFENSE, citada en la Unidad II como líder hispanoamericano). Esto garantiza la frecuencia (mínimo un contacto mensual), la pertinencia (contenido localizado, no traducciones genéricas) y la diversidad de canales (email, videos cortos, banners). El proveedor gestiona el servicio, liberando al IT interno.
    - **Responsable:** Un **Proveedor Externo (Servicio Gestionado)**. El IT Interno actúa como enlace y supervisor.
- **Acción 2: Simulaciones de Phishing Trimestrales (Medición).** La plataforma contratada debe ejecutar simulaciones de phishing realistas. Como indica la Unidad II ("Medición"), esta es la métrica clave. Mide la eficacia (el porcentaje de *clicks* y, más importante, el de *reportes*), no solo la participación. Los resultados (anónimos por sector) se reportan a la Dirección como el KPI del "Firewall Humano".
    - **Responsable:** Responsable: **El Jefe de Sistemas (como supervisor)**. La ejecución técnica la realiza la plataforma contratada (Proveedor Externo); el Jefe de Sistemas define los objetivos, aprueba las plantillas de phishing y analiza los reportes de eficacia para el Comité de Crisis.
- **Acción 3: Gamificación y Reporte (El "Firewall Humano" en Acción).** Se debe implementar un botón de "Reportar Phishing" fácil de usar en M365. Para fomentar la cultura (según **Unidad II - "Gamificación"**), se debe crear un ranking *positivo* (no punitivo), premiando al "Sector más seguro" (aquel que más reporta correos sospechosos).
    - **Responsable:** El Proveedor Externo (configuración inicial del botón) y el IT Interno (monitoreo de los reportes).

2.3. Plan de Reducción de Riesgos contra el Ransomware (Prevención)

Justificación Lógica (Unidad III): La amenaza del ransomware ha mutado. Ya no es un simple cifrado, sino un modelo de negocio industrializado (RaaS - Ransomware as a Service) que opera con mercados de acceso (IAB - Initial Access Broker). La amenaza principal, como se detalla en la Unidad III, es la Doble Extorsión (Doxing): el atacante primero exfiltra los datos (ataque a la Confidencialidad) y luego cifra (ataque a la Disponibilidad).

Esta táctica anula por completo la estrategia de "solo restaurar backups", ya que la amenaza de publicar historias clínicas sensibles persiste. La infraestructura de "Clínicas Privadas del Centro S.A." (descrita en la Sección 1) es un objetivo ideal para este ataque: sus servidores Windows 2012 R2 y SQL 2008 R2 son vulnerabilidades conocidas y no parcheadas; su red interna plana facilita el movimiento lateral; y su acceso RDP publicado es un vector de entrada directo.

El siguiente plan prioriza los controles no por costo, sino por impacto en la mitigación de los vectores más probables (identificados en el Gráfico de la Unidad IV) y en la limitación del daño (movimiento lateral).

Plan de Prevención Priorizado:

Prioridad 1: Contener los Vectores de Entrada Principales (Email y Perímetro)

- **Acción: Implementación de MFA (Autenticación Multifactor).**
  - **Detalle:** El Gráfico de la **Unidad IV** indica que el 35% de los ataques provienen de "Credential Compromise / RDP". La configuración actual de la clínica (Sección 1), con RDP publicado directamente a Internet para proveedores y administrativos, es una invitación directa a este vector. El MFA es la contramedida técnica más eficaz y con mayor ROI para este riesgo. Debe implementarse de forma obligatoria para *todo* acceso remoto (VPN, RDP y acceso a M365).
  - **Justificación:** Esto requiere una inversión (probablemente actualizar las licencias de M365 Business Standard a P1/P2), pero el costo es marginal comparado con el riesgo que mitiga. El Jefe de Sistemas debe liderar este proyecto, ya que M365 lo facilita técnicamente.
  - **Responsable:** Responsable: **Proveedor Externo (Partner de Microsoft)** para la implementación técnica. El **IT Interno (Jefe de Sistemas)** actúa como contraparte, validando la configuración, gestionando la comunicación interna y supervisando el *roll-out* a los usuarios.
- **Acción: Filtrado Avanzado de Email (Anti-Phishing).**
  - **Detalle:** El vector de ataque #1, con un 44% (Gráfico **Unidad IV**), es el Phishing. El plan de M365 Business Standard (Sección 1) ofrece una protección de correo básica que no incluye *sandboxing* de adjuntos ni reescritura de URLs maliciosas. Esta brecha debe cerrarse.
  - **Justificación:** Como el equipo de IT no puede gestionar reglas de filtrado complejas, se debe contratar un servicio de *gateway* de correo en la nube (ej. Proofpoint, Mimecast, o el upgrade a *Defender for Office 365*). Este servicio (OPEX mensual) es un control preventivo esencial contra el vector más probable.
  - **Responsable:** Un **Proveedor Externo (MSP)** para la implementación y gestión del servicio.

Prioridad 2: Implementar Resiliencia (Backup Inmutable y Gestión de Parches)

- **Acción: Estrategia 3-2-1 con Inmutabilidad (Revisión de Backups).**
  - **Detalle:** La estrategia actual (Sección 1) de backups a un NAS en la misma red y un disco USB rotado manualmente es catastróficamente insuficiente. Como se explica en la **Unidad IV**, el ransomware moderno "caza" los backups: escanea la red en busca de recursos compartidos (como el NAS) y los cifra primero, antes de atacar los servidores.
  - **Justificación:** La regla 3-2-1 (3 copias, 2 medios) solo es válida si la copia "1" (externa) es inmutable (solo lectura) u offline (físicamente desconectada). La clínica debe implementar urgentemente una de dos soluciones: 1) Un BaaS (Backup as a Service) en la nube que garantice la inmutabilidad (ej. con Object Lock), o 2) Una rotación disciplinada de cintas LTO almacenadas fuera de las instalaciones. Se debe realizar una prueba de restauración completa trimestralmente.

    - **Responsable: Proveedor Externo (para implementar el BaaS)** o el **IT Interno (para gestionar cintas)**. Se recomienda el BaaS para liberar al IT interno de tareas manuales.
- **Acción: Plan de Gestión de Parches y Migración de Servidores Obsoletos.**
    - **Detalle:** La Unidad III lista el *Patch Management* como una "Buena Práctica" fundamental. El Análisis de Vulnerabilidades (Punto 2.1) confirmará que los servidores Windows 2012 R2 y SQL 2008 R2 (Sección 1), sobre los que corre el HIS/EMR, son el riesgo de seguridad más alto de la organización.
    - **Justificación:** Esto no es un simple parcheo; es un proyecto de migración de infraestructura crítica. El equipo de IT de 3 personas no puede migrar una base de datos de HIS y un servidor de aplicaciones mientras mantiene la operación. Se debe contratar un proyecto externo para migrar el HIS/EMR a un sistema operativo y BBDD con soporte.
    - **Responsable:** Un Proveedor Externo (Consultora de Infraestructura) para el proyecto de migración. El IT Interno supervisará y aprobará los parches mensuales (cuya instalación puede ser automatizada por un MSP), pero el proyecto de migración de servidores obsoletos es 100% externo.

Prioridad 3: Limitar el "Blast Radius" (Segmentación y Detección)

- **Acción: Microsegmentación de Red.**
    - **Detalle:** El control clave contra el **movimiento lateral** (**Unidad III**). La red plana (Sección 1) permite que un ataque que infecta una PC de Administración (vía Phishing) pueda escanear la red y atacar directamente el servidor HIS/EMR. Se deben crear VLANs separadas y con reglas de firewall estrictas entre ellas para: 1) Administración (RRHH, Finanzas), 2) Operación Clínica (HIS/EMR), 3) Equipos Médicos (OT), y 4) Servidores de Dominio.
    - **Justificación:** Una PC de Administración *nunca* debe poder iniciar una conexión RDP o SMB al servidor de base de datos. Este control convierte un incidente catastrófico (toda la red cifrada) en un incidente contenido (una PC aislada).
    - **Responsable:** Un **Proveedor Externo (Consultora de Redes)**. Esta es una re-arquitectura de red compleja que el IT interno no puede ejecutar.
- **Acción: Contratación de un SOC/SIEM Gestionado.**
    - **Detalle:** El equipo de 3 personas es ciego; no tiene monitoreo de logs. Esta es la única forma realista de implementar un **Blue Team (Unidad I)**. Un SOC (Centro de Operaciones de Seguridad) externo instalará agentes en los servidores críticos (Controladores de Dominio, Servidor HIS) y en el firewall para centralizar y correlacionar eventos.
    - **Justificación:** Su objetivo principal será detectar la **Doble Extorsión (Unidad III)** en progreso. Un SOC puede alertar en tiempo real sobre comportamientos anómalos (ej. una PC de Administración intentando escanear la red, o una gran transferencia de datos saliente hacia una IP desconocida) *antes* de que ocurra el cifrado.
    - **Responsable:** Un **Proveedor Externo (MSP con servicio de SOC)**.

2.4. Plan de Acción ante Detección de Ransomware (Respuesta)

Justificación Lógica (Unidad IV): Asumir que la prevención fallará. Como enseña la **Unidad IV**, la seguridad 100% no existe. El objetivo de este plan no es evitar el incidente, sino garantizar la **resiliencia del negocio**. La meta es minimizar el *downtime* (que la **Unidad IV** sitúa en un promedio de 3 semanas) y gestionar la crisis operativa y legal de forma estructurada. Este plan **debe ser liderado por la Dirección General**, no por el Jefe de Sistemas.

Fase 0: Preparación (Antes del Incidente)

- **Acción: Formalizar el Comité de Crisis y la Política de NO PAGO.**
    - **Detalle:** Como exige la Unidad IV, la decisión de "Pagar o No Pagar" debe tomarse *en frío*. El Comité (Director General, Director Médico, Jefe de IT, Jefe

de Legales, Jefe de Finanzas, y un Vocero de Comunicación) debe reunirse y documentar la Política de NO PAGO.
    - **Justificación:** Se justifica el "NO PAGO" por las razones de la Unidad IV: 1) No hay garantía de recuperar los datos, 2) No hay garantía de que no vuelvan a atacar, 3) Se financia una actividad criminal, y 4) (clave en la Doble Extorsión) el pago no garantiza que los datos exfiltrados sean destruidos.
    - **Responsable:** La **Dirección General**.
- **Acción: Firmar un Contrato (Retainer) con un Proveedor Forense.**
    - **Detalle:** No se puede perder tiempo buscando un "Aliado Especializado" (**Unidad IV**) mientras la clínica está paralizada. Se debe tener un contrato de *retainer* (pago previo por disponibilidad) con una firma de Respuesta a Incidentes (IR), forensia y negociación (aunque la política sea no pagar, se negocia para ganar tiempo).
    - **Justificación:** Este proveedor debe ser **independiente** del MSP habitual para evitar conflictos de interés (el MSP no puede auditar su propio fallo). Este es el primer número al que llamará el Jefe de IT.
    - **Responsable:** La **Dirección (Legales y Finanzas)**.

Fase 1: Detección y Contención (Día Cero)

- **Acción: Aislamiento Inmediato.**
    - **Detalle:** En el momento en que se recibe una alerta (del "Firewall Humano" - Unidad II, o del SOC Externo - Unidad I), el equipo de IT interno debe estar facultado y entrenado para "desconectar" los segmentos de red afectados o apagar los *switches* principales.
    - **Justificación:** Contener la propagación (movimiento lateral) es la prioridad absoluta. Inmediatamente después, el Jefe de IT activa al Comité de Crisis y al Proveedor Forense.
    - **Responsable:** El **IT Interno**.

Fase 2: Análisis y Erradicación

- **Acción: Activación del Proveedor Forense (Retainer).**
    - **Detalle:** El **Aliado Especializado (Unidad IV)** toma el control del análisis. Su misión es: 1) Realizar la **Forensia** para identificar el *paciente cero* y el vector de entrada (ej. el RDP de la Sección 1). 2) Identificar la cepa (con herramientas como NoMoreRansom - **Unidad IV**). 3) Identificar el alcance (qué otros servidores están comprometidos). 4) **Determinar el alcance de la exfiltración (Doble Extorsión)**.
    - **Justificación:** Este último punto (Doxing) es el más crítico, ya que define la respuesta legal y de comunicación, independientemente de la restauración de los backups.
    - **Responsable:** El **Proveedor Externo (Forense)**, con el soporte del IT Interno.

Fase 3: Recuperación y Comunicación

- **Acción: Restauración desde Backups Inmutables.**
    - **Detalle:** Solo cuando el equipo forense certifica que el entorno está limpio y el vector de entrada ha sido cerrado (ej. RDP deshabilitado, cuenta comprometida bloqueada), se inicia la restauración.
    - **Justificación:** Es vital restaurar *únicamente* desde los **backups offline/inmutables** (definidos en 2.3). Restaurar desde el NAS infectado (Sección 1) simplemente reiniciaría el ataque. El Director Médico debe activar el plan de contingencia operativa (atención con formularios en papel) durante este tiempo.
    - **Responsable:** El **IT Interno** (ejecuta la restauración).
- **Acción: Ejecución del Plan de Comunicación.**
    - **Detalle:** El Vocero designado (no el Jefe de IT) activa el plan de comunicación (**Unidad IV**). Se debe dar un mensaje unificado a empleados, prensa y pacientes.

- **Justificación:** Si el forense confirma la exfiltración de historias clínicas, el Jefe de Legales debe preparar la **notificación obligatoria a los pacientes afectados y a la Autoridad de Control** (Ley 25.326 - Art. 17). Esto no es opcional y tiene implicancias legales y reputacionales severas.
- **Responsable:** El **Comité de Crisis (Vocero y Legales)**.

Fase 4: Post-Incidente (Lecciones Aprendidas)

- **Acción: Retroalimentación del Ciclo de Seguridad.**
  - **Detalle:** El informe forense final no es el fin del proceso, sino el comienzo del siguiente. Detallará la causa raíz (ej. "el atacante entró por el RDP abierto y escaló privilegios usando la vulnerabilidad del Windows Server 2012 R2").
  - **Justificación:** Este informe, como dicta la **Unidad IV**, es la herramienta que el Jefe de Sistemas usará para **forzar la financiación** del proyecto de migración de servidores (Punto 2.3) que quizás fue pospuesto. El ciclo de evaluación (Unidad I) se reinicia.
  - **Responsable:** El **Comité de Crisis (Dirección + IT)**.

Anexo

Matriz de Responsabilidades (RACI) para Respuesta a Incidentes

Explicación y Justificación:

Este anexo es la **piedra angular del Plan de Respuesta (Punto 2.4)**. Responde a la pregunta más crítica: "En medio de una crisis, ¿quién hace qué?".

Una falla común en organizaciones inmaduras es que el Jefe de IT asume toda la responsabilidad, incluyendo decisiones de negocio (como la comunicación) para las que no está calificado. Esta matriz demuestra una comprensión avanzada de la **gobernanza** (Unidad I) y el **BCP (Business Continuity Planning)** (Unidad IV).

Separa claramente la ejecución técnica (R) de la responsabilidad de negocio (A), asegurando que el Comité de Crisis lidere y el IT ejecute.

Definiciones de la Matriz:

- **R (Responsible):** El que *ejecuta* la tarea.
- **A (Accountable):** El *dueño* final y responsable de la tarea (solo puede haber uno por fila).
- **C (Consulted):** El que debe ser *consultado* (comunicación bidireccional).
- **I (Informed):** El que debe ser *informado* (comunicación unidireccional).

Actividad del Incidente (Punto 2.4)	IT Interno (Jefe de Sist.)	Comité de Crisis (Dirección)	Proveedor Forense (Externo)	Depto. de Legales	Vocero (Comunicación)
1. Detección y Alerta Inicial	R	I			
2. Aislamiento de Sistemas (Contención)	**A / R**	I	C		I
3. Activación de Proveedor Externo	R	**A**	C	I	
4. Análisis Forense (Investigación)	C	I	**A / R**	C	
5. Decisión de Restauración	C	**A**	C		
6. Ejecución de Restauración (Backup)	**A / R**	I	C		
7. Comunicación Legal (a Pacientes / Ente)	I	**A**	C	**R**	C
8. Comunicación Pública / Prensa	I	**A**		C	**R**
9. Cierre de Incidente y Lecciones	R	**A**	C	I	I